

TÍTULO

Laboratorio Red Team con escenarios de ataque reproducibles

**TRABAJO DE FIN DE MÁSTER
EN CIBERSEGURIDAD**

Jose Tomas Torre Pedroarena

Julio, 2026



TÍTULO

Red Team Lab with Reproducible Attack Scenarios

**TRABAJO DE FIN DE MÁSTER
EN CIBERSEGURIDAD**

Jose Tomas Torre Pedroarena

Roberto López Santoyo

Julio, 2026

Resumen

Texto con, a lo sumo, 200 palabras.

Palabras Clave

Palabras clave

Abstract

Resumen anterior, en inglés.

Keywords

Keywords

Índice

Capítulo 1 Introducción.	1
1.1 Contexto y motivación.	2
1.2 Objetivos del trabajo	2
1.2.1 Objetivo general	2
1.2.2 Objetivos específicos	2
1.3 Alcance y limitaciones	3
1.4 Organización de la memoria	3
Capítulo 2 Fundamentos teóricos	5
2.1 OWASP Top 10.	5
2.2 MITRE ATT&CK	7
2.3 SQL Injection	8
2.4 Cross-Site Scripting (XSS).	8
2.5 Vulnerabilidades de carga de archivos (File Upload)	9
2.6 Exposición de credenciales	9
2.7 Escalada de privilegios en Linux	10
2.7.1 PATH Hijacking	10
2.7.2 Configuraciones inseguras	11
2.8 Pivoting y segmentación de red	11
2.9 Active Directory.	13
2.9.1 Componentes principales.	13
2.9.2 Usuarios, grupos y permisos	14
2.10 Protocolos y servicios utilizados	14
2.10.1 SMB	15
2.10.2 WinRM	15
2.11 Movimiento lateral en entornos Windows	16
Capítulo 3 Gestión y metodología del proyecto	17
3.1 Metodología de desarrollo	17
3.2 Planificación del proyecto	17
3.3 Recursos utilizados	19
3.3.1 Hardware	19
3.3.2 Software	22
Capítulo 4 Análisis del entorno y requisitos	23
4.1 Requisitos funcionales	23
4.2 Requisitos no funcionales	24
4.3 Análisis de amenazas y superficie de ataque.	25
4.4 Justificación del uso de OWASP y MITRE ATT&CK	28

Capítulo 5 Diseño del laboratorio	29
5.1 Arquitectura general	29
5.1.1 Arquitectura física	30
5.1.2 Arquitectura lógica	30
5.1.3 Segmentación de red	31
5.1.4 Diagrama completo de infraestructura	32
5.2 Diseño del servidor vulnerable	32
5.2.1 Stack tecnológico	32
5.2.2 Portal PYME vulnerable	33
5.2.3 Vulnerabilidades implementadas	34
5.3 Diseño de la infraestructura Active Directory	35
5.3.1 DC01	35
5.3.2 DEV01	35
5.3.3 Usuarios y políticas	36
5.3.4 Servicios internos	36
5.4 Diseño del escenario ofensivo	37
5.5 Automatización y despliegue	37
5.5.1 Docker	37
5.5.2 Reproducibilidad del laboratorio	38
5.6 Repositorio y estructura del proyecto	38
Capítulo 6 Validación y explotación del laboratorio	39
6.1 Metodología de pruebas	39
6.2 Escenarios de ataque realizados	40
6.2.1 Reconocimiento inicial	40
6.2.2 Explotación web	40
6.2.3 Obtención de reverse shell	41
6.2.4 Escalada de privilegios Linux	41
6.2.5 Pivoting	41
6.2.6 Enumeración Active Directory	41
6.2.7 Movimiento lateral	42
6.2.8 Compromiso del dominio	42
6.3 Validación de reproducibilidad	42
Capítulo 7 Conclusiones y trabajo futuro	43
7.1 Conclusiones	43
7.2 Líneas futuras	43
Bibliografía	44
Anexo i - Manual de despliegue	46

Anexo ii - Manual de explotación	47
Anexo iii - Configuración de red	48
Anexo iv - Scripts y automatizaciones	49
Anexo v - Evidencias adicionales.	50
Glosario de términos	51

Índice de figuras

1	Tácticas MITRE ATT&CK relacionadas con la cadena de ataque del laboratorio.	7
2	Ejemplo conceptual de una operación de <i>pivoting</i> sobre una red segmentada. Autor: Rafael Núñez Aponte	12
3	Logotipo de Active Directory.	13
4	Escenarios de despliegue del laboratorio: con máquina atacante externa y utilizando el propio equipo anfitrión como atacante.	20
5	Tamaño aproximado del laboratorio desplegado en el equipo anfitrión, incluyendo máquina atacante.	21
6	Diagrama general de alto nivel del laboratorio, mostrando los principales componentes y su interconexión.	24
7	Flujo general de ataque planteado en el laboratorio.	27

Índice de tablas

1	Relación entre OWASP Top 10 2025 y vulnerabilidades implementadas en el laboratorio	6
2	Recursos mínimos recomendados para las máquinas virtuales del laboratorio	19
3	Resumen de requisitos no funcionales	25
4	Activos y vectores de ataque considerados	26
5	Relación entre componentes del laboratorio y marcos de referencia	28
6	Stack tecnológico utilizado en el servidor vulnerable	33
7	Categorías de vulnerabilidades implementadas en el laboratorio	34

Capítulo 1

Introducción

La ciberseguridad se ha convertido en uno de los principales retos tecnológicos para las organizaciones actuales. La digitalización de procesos, la exposición de servicios web y la interconexión entre sistemas internos han incrementado la superficie de ataque disponible para posibles actores maliciosos. En este contexto, resulta fundamental comprender cómo se producen las intrusiones, qué debilidades suelen ser explotadas y cómo se encadenan distintas técnicas ofensivas hasta comprometer un entorno corporativo.

La formación práctica en ciberseguridad requiere entornos controlados donde sea posible analizar vulnerabilidades, ejecutar ataques y estudiar su impacto sin afectar a sistemas reales. Aunque existen laboratorios y máquinas vulnerables orientadas al aprendizaje, muchos de estos entornos se centran en ejercicios aislados o en una única máquina objetivo. Esto limita la posibilidad de representar una cadena de ataque completa que incluya acceso inicial, explotación, escalada de privilegios, pivoting, enumeración interna y movimiento lateral.

El presente Trabajo Fin de Máster aborda el diseño e implementación de un laboratorio Red Team reproducible, orientado a la simulación de ataques en un entorno corporativo controlado. Para ello, se ha diseñado una infraestructura compuesta por un servidor web vulnerable, una red interna segmentada y sistemas Windows integrados en un dominio Active Directory. La aplicación web simula un portal corporativo con funcionalidades habituales en una organización, como gestión de usuarios, empleados, clientes o tickets, con el objetivo de disponer de un escenario realista sobre el que introducir y explotar vulnerabilidades.

Las vulnerabilidades incorporadas en el laboratorio toman como referencia las categorías recogidas en OWASP Top 10, al tratarse de uno de los marcos más utilizados para clasificar riesgos de seguridad en aplicaciones web. Además, los escenarios ofensivos se relacionan con técnicas contempladas en MITRE ATT&CK, lo que permite conectar las acciones realizadas en el laboratorio con tácticas y procedimientos empleados en ataques reales.

El resultado esperado es un entorno práctico, modular y reproducible que permita estudiar el ciclo completo de una intrusión en un escenario controlado. Este laboratorio no pretende representar una organización concreta, sino proporcionar una base técnica suficientemente realista para practicar y documentar técnicas ofensivas aplicables a entornos empresariales.

1.1 Contexto y motivación

La creciente digitalización de los entornos corporativos ha incrementado la exposición de aplicaciones web, servicios internos y sistemas interconectados. Este contexto ha provocado que la ciberseguridad sea un aspecto clave para comprender cómo se producen los ataques, qué vulnerabilidades suelen ser explotadas y cómo un acceso inicial puede derivar en el compromiso de otros sistemas internos.

Muchos laboratorios de aprendizaje se centran en máquinas aisladas o vulnerabilidades concretas, lo que limita la representación de una intrusión completa. Por ello, este trabajo plantea el diseño de un laboratorio Red Team reproducible que permita practicar una cadena de ataque más realista, incluyendo explotación web, escalada de privilegios, pivoting, enumeración interna y movimiento lateral.

La motivación principal del proyecto es disponer de un entorno controlado y documentado que facilite el aprendizaje práctico de técnicas ofensivas sin afectar a sistemas reales. Para ello, el laboratorio combina un servidor web vulnerable, una red interna segmentada y una infraestructura Windows basada en Active Directory.

1.2 Objetivos del trabajo

El presente Trabajo Fin de Máster tiene como finalidad diseñar e implementar un laboratorio de ciberseguridad orientado a la simulación de escenarios de ataque en entornos corporativos. Para ello, se ha desarrollado una infraestructura reproducible que integra diferentes sistemas y servicios con el objetivo de representar de forma realista las distintas fases de una intrusión, desde el acceso inicial hasta el compromiso de recursos internos.

Además del desarrollo técnico del laboratorio, el proyecto busca proporcionar una plataforma práctica que permita analizar vulnerabilidades, validar técnicas ofensivas y facilitar el aprendizaje de conceptos relacionados con la seguridad de aplicaciones web, la segmentación de redes y los entornos basados en Active Directory.

1.2.1 Objetivo general

Diseñar e implementar un laboratorio Red Team reproducible que permita simular y documentar escenarios de ataque realistas sobre una infraestructura corporativa controlada, integrando vulnerabilidades web, sistemas Windows y técnicas de post-explotación.

1.2.2 Objetivos específicos

Para alcanzar el objetivo general se han definido los siguientes objetivos específicos:

- Diseñar una arquitectura de laboratorio segmentada que simule un entorno corporativo realista.
- Implementar un servidor web vulnerable basado en tecnologías ampliamente utilizadas en entornos empresariales.
- Incorporar vulnerabilidades representativas del estándar OWASP Top 10 para su posterior explotación y análisis.
- Desplegar una infraestructura Windows basada en Active Directory que permita simular escenarios de red internos.
- Implementar técnicas de pivoting y movimiento lateral entre los distintos sistemas del laboratorio.
- Automatizar el despliegue y configuración del entorno para facilitar su reproducibilidad.
- Documentar el proceso de explotación y validación de los diferentes escenarios de ataque implementados. ““

1.3 Alcance y limitaciones

El alcance de este trabajo comprende el diseño, implementación y validación de un laboratorio de ciberseguridad orientado a la simulación de ataques en un entorno controlado. El laboratorio incluye una aplicación web vulnerable, una infraestructura Active Directory básica y los mecanismos necesarios para reproducir técnicas de explotación, escalada de privilegios y movimiento lateral.

No obstante, el proyecto presenta ciertas limitaciones. El entorno ha sido desarrollado con fines exclusivamente académicos y formativos, por lo que las vulnerabilidades presentes han sido introducidas de forma intencionada. Asimismo, la infraestructura implementada representa una simplificación de los entornos corporativos reales y no pretende reproducir la totalidad de servicios, políticas de seguridad o mecanismos de monitorización que pueden encontrarse en organizaciones de mayor complejidad.

1.4 Organización de la memoria

La memoria se estructura en seis capítulos principales. En primer lugar, se presenta el contexto del trabajo, los objetivos perseguidos y el alcance del proyecto. Posteriormente,

se describe la metodología empleada, la planificación realizada y los recursos utilizados durante el desarrollo.

A continuación, se analizan los requisitos y las necesidades que han motivado el diseño del laboratorio. Seguidamente, se detalla la arquitectura implementada, los componentes que forman parte de la infraestructura y las decisiones de diseño adoptadas.

Los capítulos posteriores se centran en la validación del entorno mediante distintos escenarios de ataque, mostrando las técnicas empleadas y los resultados obtenidos. Finalmente, se presentan las conclusiones del trabajo y las posibles líneas de evolución futura del proyecto. La memoria se complementa con diversos anexos que incluyen documentación técnica, manuales de despliegue y material de apoyo.

Capítulo 2

Fundamentos teóricos

El desarrollo de un laboratorio orientado a ejercicios de Red Team requiere comprender los principales conceptos, vulnerabilidades y técnicas empleados tanto por atacantes como por profesionales de la seguridad ofensiva. Este capítulo presenta los fundamentos teóricos necesarios para entender los escenarios implementados posteriormente en el laboratorio y las distintas fases de explotación desarrolladas durante las pruebas de validación.

Se describen las principales categorías de vulnerabilidades utilizadas en la aplicación web, los conceptos asociados a infraestructuras Active Directory, así como las técnicas de pivoting, movimiento lateral y escalada de privilegios empleadas durante los ejercicios prácticos.

2.1 OWASP Top 10

OWASP Top 10 es uno de los estándares de referencia más utilizados para clasificar los riesgos de seguridad más relevantes presentes en aplicaciones web. Publicado periódicamente por la organización Open Worldwide Application Security Project (OWASP), recopila las categorías de vulnerabilidades que generan un mayor impacto sobre la seguridad de aplicaciones reales¹.

La edición de 2025 mantiene *Broken Access Control* como la categoría de riesgo más crítica e introduce cambios significativos respecto a versiones anteriores, como la incorporación de *Software Supply Chain Failures* o la nueva categoría *Mishandling of Exceptional Conditions*. Asimismo, categorías clásicas como *Injection*, *Security Misconfiguration* o *Authentication Failures* continúan ocupando posiciones destacadas dentro de la clasificación.

En este proyecto, OWASP Top 10 se utiliza como marco de referencia para seleccionar las vulnerabilidades implementadas en el portal vulnerable. El objetivo no consiste en reproducir todas las categorías presentes en el estándar, sino aquellas que permiten construir una cadena de ataque realista dentro de un entorno corporativo tipo PYME.

¹OWASP Foundation, *OWASP Top 10:2025*, Consultado en junio de 2026, 2025. dirección: https://owasp.org/Top10/2025/0x00_2025-Introduction/

Tabla 1 Relación entre OWASP Top 10 2025 y vulnerabilidades implementadas en el laboratorio

ID	Categoría OWASP 2025	Ejemplo en entorno PYME	Uso en el laboratorio
A01	Broken Access Control	Acceso no autorizado a datos o funciones de otros usuarios	Implementada
A02	Security Misconfiguration	Servicios mal configurados, errores visibles o archivos sensibles expuestos	Implementada
A03	Software Supply Chain Failures	Dependencias vulnerables o componentes externos comprometidos	No prioritaria
A04	Cryptographic Failures	Contraseñas débiles, hashes inseguros o datos sensibles mal protegidos	Implementada
A05	Injection	SQL Injection, XSS o inyección de comandos	Implementada
A06	Insecure Design	Flujos inseguros por falta de diseño seguro o threat modeling	Parcial
A07	Authentication Failures	Sesiones inseguras, credenciales débiles o reutilización de contraseñas	Implementada
A08	Software or Data Integrity Failures	Falta de verificación de integridad en datos, código o actualizaciones	No prioritaria
A09	Security Logging & Alerting Failures	Ausencia de registros o alertas ante acciones sospechosas	Parcial
A10	Mishandling of Exceptional Conditions	Errores que revelan rutas, consultas, stack traces o información interna	Implementada

Las categorías marcadas en verde corresponden a vulnerabilidades que han sido implementadas total o parcialmente durante el diseño del laboratorio. Su selección responde a criterios de realismo, relevancia práctica y capacidad para encadenar diferentes fases de explotación dentro de un escenario ofensivo completo.

En primer lugar, las vulnerabilidades de control de acceso, autenticación e inyección permiten reproducir el acceso inicial al entorno. En segundo lugar, las configuraciones inseguras, fallos criptográficos y exposición de credenciales facilitan la transición hacia fases de post-explotación. Finalmente, la gestión deficiente de errores y la falta de registro o alerta permiten simular situaciones en las que el atacante puede avanzar sin ser detectado con facilidad.

Por tanto, OWASP Top 10 no se utiliza únicamente como una lista de vulnerabilidades aisladas, sino como una guía para seleccionar debilidades que puedan encadenarse dentro de un escenario ofensivo completo.

2.2 MITRE ATT&CK

MITRE ATT&CK (*Adversarial Tactics, Techniques and Common Knowledge*) es una base de conocimiento desarrollada por MITRE Corporation que documenta tácticas y técnicas empleadas por atacantes reales durante operaciones ofensivas sobre sistemas informáticos².

A diferencia de OWASP Top 10, cuyo enfoque se centra principalmente en vulnerabilidades presentes en aplicaciones web, MITRE ATT&CK permite modelar el comportamiento del atacante una vez que se ha iniciado el proceso de compromiso. Para ello organiza las técnicas ofensivas en distintas tácticas que representan objetivos concretos dentro de una intrusión.

En este trabajo, MITRE ATT&CK se utiliza como referencia para relacionar las diferentes fases del laboratorio con técnicas ampliamente reconocidas por la comunidad de ciberseguridad. De este modo, actividades como la explotación web, la obtención de una reverse shell, la escalada de privilegios o el movimiento lateral pueden asociarse con tácticas descritas dentro del marco ATT&CK.

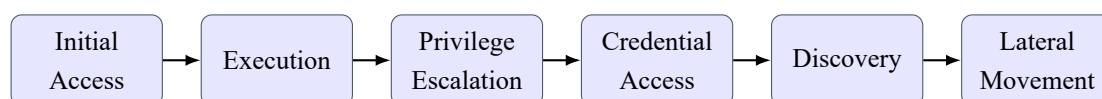


Figura 1 Tácticas MITRE ATT&CK relacionadas con la cadena de ataque del laboratorio.

²MITRE Corporation, *MITRE ATT&CK Framework*, Consultado en junio de 2026, 2025. dirección: <https://attack.mitre.org/>

La Figura 1 resume las tácticas ATT&CK más relevantes para los escenarios desarrollados en el laboratorio. Estas fases permiten relacionar la explotación práctica realizada durante el TFM con una taxonomía ampliamente utilizada en ejercicios de Red Team, análisis de amenazas y respuesta ante incidentes.

2.3 SQL Injection

La inyección SQL (*SQL Injection* o SQLi) es una vulnerabilidad de inyección que aparece cuando una aplicación construye consultas SQL utilizando datos proporcionados por el usuario sin aplicar controles adecuados de validación, parametrización o separación entre datos e instrucciones. OWASP la identifica como una de las vulnerabilidades clásicas dentro de la categoría de inyección³.

Un atacante puede aprovechar este fallo para modificar la lógica de una consulta legítima y acceder a información no autorizada, alterar datos almacenados o, en determinados escenarios, realizar acciones administrativas sobre la base de datos. La guía de pruebas de OWASP incluye SQL Injection dentro de las técnicas de validación de entrada más relevantes para aplicaciones web⁴.

En el contexto de este laboratorio, SQL Injection se utiliza como uno de los posibles vectores de acceso inicial al sistema. Su inclusión permite simular un fallo frecuente en aplicaciones corporativas donde formularios de autenticación, búsqueda o consulta interactúan directamente con una base de datos.

2.4 Cross-Site Scripting (XSS)

Cross-Site Scripting (XSS) es una vulnerabilidad que permite introducir código JavaScript no confiable en una página web, de forma que este pueda ejecutarse en el navegador de otros usuarios. OWASP destaca que este tipo de vulnerabilidad puede permitir la ejecución de acciones en nombre de la víctima, el robo de información sensible o la modificación del contenido mostrado por la aplicación⁵.

Estas vulnerabilidades aparecen cuando una aplicación muestra datos proporcionados por el usuario sin aplicar mecanismos adecuados de validación y codificación de salida.

³OWASP Foundation, *SQL Injection Prevention Cheat Sheet*, Consultado en junio de 2026, 2025. dirección: https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

⁴OWASP Foundation, *Testing for SQL Injection*, Consultado en junio de 2026, 2025. dirección: https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/07-Input_Validation_Testing/05-Testing_for_SQL_Injection

⁵OWASP Foundation, *Cross Site Scripting Prevention Cheat Sheet*, Consultado en junio de 2026, 2025. dirección: https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

Dependiendo de su funcionamiento, OWASP distingue diferentes variantes, entre las que destacan el XSS reflejado, el XSS almacenado y el XSS basado en DOM⁶.

Dentro del laboratorio, XSS se utiliza para representar un fallo habitual en portales web donde existen formularios, campos de entrada o funcionalidades de gestión de contenido. Su implementación permite analizar el impacto de no tratar correctamente los datos introducidos por los usuarios y estudiar cómo una vulnerabilidad de cliente puede afectar a la seguridad global de la aplicación.

2.5 Vulnerabilidades de carga de archivos (File Upload)

Las funcionalidades de carga de archivos (*File Upload*) constituyen una superficie de ataque habitual en aplicaciones web modernas, especialmente en portales corporativos que permiten adjuntar documentos, imágenes o evidencias a formularios internos.

Cuando una aplicación no valida correctamente los archivos recibidos, un atacante puede subir contenido malicioso con el objetivo de ejecutar código en el servidor, almacenar ficheros peligrosos o comprometer a otros usuarios del sistema. OWASP destaca que este tipo de funcionalidad debe validar aspectos como la extensión, el tipo MIME, el tamaño, el nombre del archivo y la ubicación final de almacenamiento⁷.

En el contexto del laboratorio, esta vulnerabilidad permite representar un escenario realista en el que una funcionalidad aparentemente legítima, como la subida de documentos o adjuntos, puede convertirse en un vector de acceso inicial o facilitar fases posteriores de post-explotación.

2.6 Exposición de credenciales

La exposición accidental de credenciales constituye una de las causas habituales de compromiso en entornos corporativos. Este problema puede manifestarse mediante archivos de configuración inseguros, copias de seguridad accesibles, credenciales embebidas en código fuente, variables de entorno expuestas o contraseñas almacenadas sin mecanismos de protección adecuados.

OWASP incluye la protección de datos sensibles y secretos dentro de sus recomendaciones de seguridad, especialmente cuando una aplicación maneja credenciales, claves, tokens o información de autenticación reutilizable⁸.

⁶OWASP Foundation, *Types of Cross-Site Scripting*, Consultado en junio de 2026, 2025. dirección: https://owasp.org/www-community/Types_of_Cross-Site_Scripting

⁷OWASP Foundation, *File Upload Cheat Sheet*, Consultado en junio de 2026, 2025. dirección: https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html

⁸OWASP Foundation, *Secrets Management Cheat Sheet*, Consultado en junio de 2026, 2025. dirección: https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html

Una vez obtenidas, estas credenciales permiten a un atacante acceder a nuevos sistemas y ampliar progresivamente el alcance de una intrusión. En entornos reales, la reutilización de contraseñas entre servicios incrementa significativamente el impacto, ya que una credencial comprometida puede servir para acceder a sistemas internos, bases de datos, servicios administrativos o recursos compartidos.

Dentro del laboratorio, la exposición de credenciales se utiliza como mecanismo para conectar la explotación web inicial con fases posteriores de escalada, pivoting y movimiento lateral.

2.7 Escalada de privilegios en Linux

La escalada de privilegios engloba el conjunto de técnicas utilizadas para obtener permisos superiores a los inicialmente concedidos a un usuario comprometido. En sistemas Linux, estas técnicas suelen aprovechar configuraciones inseguras, permisos excesivos sobre ficheros, tareas programadas, binarios con privilegios elevados o scripts administrativos mal diseñados.

Desde el punto de vista de MITRE ATT&CK, la escalada de privilegios constituye una táctica propia cuyo objetivo es obtener un nivel de acceso superior dentro del sistema comprometido⁹.

En el laboratorio, esta fase permite transformar un acceso inicial limitado sobre el servidor Ubuntu en un control completo del sistema. Esto resulta fundamental para continuar la cadena ofensiva, ya que permite acceder a información interna, modificar configuraciones, preparar mecanismos de pivoting y obtener credenciales útiles para comprometer otros sistemas de la infraestructura.

2.7.1 PATH Hijacking

PATH Hijacking es una técnica de escalada de privilegios que aprovecha configuraciones inseguras relacionadas con la variable de entorno **PATH**. Esta variable define los directorios en los que el sistema busca ejecutables cuando se invoca un comando sin indicar su ruta absoluta.

El riesgo aparece cuando un script o programa ejecutado con privilegios elevados llama a comandos del sistema sin utilizar rutas absolutas. En ese caso, un atacante puede situar un ejecutable malicioso con el mismo nombre en un directorio controlado y modificar el orden de búsqueda de **PATH** para que dicho ejecutable sea invocado antes que el binario legítimo. La documentación de GNU Bash describe el uso de variables de entorno

⁹MITRE Corporation, *Privilege Escalation*, Consultado en junio de 2026, 2025. dirección: <https://attack.mitre.org/tactics/TA0004/>

como PATH y su influencia en la ejecución de comandos dentro del intérprete¹⁰.

En el laboratorio, esta técnica se utiliza como ejemplo de escalada de privilegios local sobre el servidor Linux comprometido. Su inclusión permite mostrar cómo una mala práctica aparentemente sencilla en un script administrativo puede transformar un acceso limitado en un compromiso completo del sistema.

2.7.2 Configuraciones inseguras

Las configuraciones inseguras representan una categoría amplia de vulnerabilidades derivadas de errores administrativos, valores por defecto inseguros o decisiones de configuración incorrectas. Este tipo de debilidad no siempre se debe a un fallo del software, sino a la forma en la que los servicios, permisos o mecanismos de autenticación han sido desplegados.

Entre los ejemplos más habituales se encuentran permisos excesivos sobre archivos, servicios innecesarios habilitados, credenciales por defecto, exposición de directorios sensibles, errores de configuración en servidores web o ausencia de cabeceras de seguridad. OWASP considera *Security Misconfiguration* una de las categorías principales dentro de los riesgos de seguridad en aplicaciones web y destaca que puede afectar tanto a la aplicación como a servidores, bases de datos, frameworks o servicios de infraestructura¹¹.

Dentro del laboratorio, las configuraciones inseguras se introducen de forma controlada para aumentar la superficie de ataque y facilitar la construcción de cadenas de explotación realistas. Este tipo de debilidad permite conectar vulnerabilidades web con fases posteriores de post-explotación, escalada de privilegios o acceso a información sensible.

2.8 Pivoting y segmentación de red

El *pivoting* es una técnica utilizada para acceder a sistemas o redes que inicialmente no son alcanzables directamente desde la posición del atacante. Para ello, se utiliza un sistema previamente comprometido como punto intermedio desde el que redirigir tráfico, crear túneles o alcanzar segmentos internos de la red.

Esta técnica resulta especialmente relevante en entornos corporativos segmentados, donde los sistemas internos no suelen estar expuestos directamente al exterior. MITRE ATT&CK recoge distintas técnicas relacionadas con el uso de proxies, túneles y mecanismos de red para canalizar comunicaciones a través de sistemas intermedios comprometidos.

¹⁰GNU Project, *Bash Reference Manual*, Consultado en junio de 2026, 2025. dirección: <https://www.gnu.org/software/bash/manual/bash.html>

¹¹OWASP Foundation, *OWASP Top 10:2025*, Consultado en junio de 2026, 2025. dirección: https://owasp.org/Top10/2025/0x00_2025-Introduction/

dos¹².

En el contexto del laboratorio, el servidor Ubuntu vulnerable actúa como punto de apoyo tras el acceso inicial. Una vez comprometido, permite alcanzar la red interna donde se encuentran los sistemas Windows y la infraestructura Active Directory. De esta forma, el laboratorio permite reproducir una situación habitual en intrusiones reales: un servicio expuesto sirve como puerta de entrada hacia sistemas internos protegidos mediante segmentación de red.

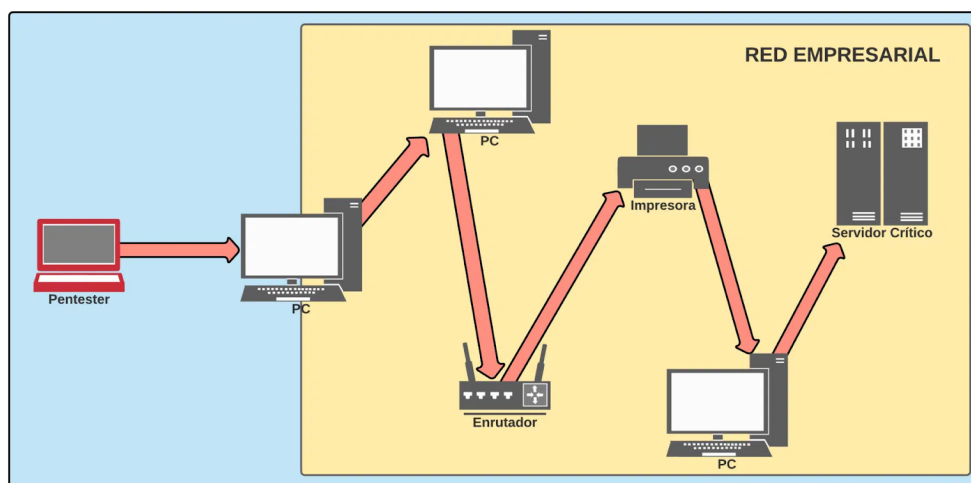


Figura 2 Ejemplo conceptual de una operación de *pivoting* sobre una red segmentada.
Autor: [Rafael Núñez Aponte](#).

¹²MITRE Corporation, *Proxy: T1090*, Consultado en junio de 2026, 2025. dirección: <https://attack.mitre.org/techniques/T1090/>

2.9 Active Directory



Figura 3 Logotipo de Active Directory.

Active Directory Domain Services (AD DS) es el servicio de directorio de Microsoft utilizado para almacenar información sobre objetos de una red, como usuarios, equipos, grupos y otros recursos. Según la documentación oficial de Microsoft, AD DS proporciona una estructura jerárquica para organizar la información del directorio y hacerla accesible a usuarios y administradores autorizados¹³.

En entornos corporativos Windows, Active Directory permite centralizar la gestión de identidades, permisos y políticas, facilitando la administración de grandes cantidades de usuarios y equipos. Por este motivo, su compromiso puede tener un impacto elevado dentro de una organización, ya que un atacante con privilegios suficientes sobre el dominio puede acceder a recursos internos, modificar configuraciones o desplazarse hacia otros sistemas.

Dentro de este TFM, Active Directory se utiliza para simular una infraestructura corporativa realista, permitiendo desarrollar escenarios de enumeración, abuso de credenciales, movimiento lateral y compromiso de sistemas internos.

2.9.1 Componentes principales

Entre los componentes fundamentales de Active Directory destacan los dominios, bosques, unidades organizativas, controladores de dominio, cuentas de usuario, cuentas de equipo y grupos de seguridad. Microsoft describe la estructura lógica de Active Directory como un modelo jerárquico que permite organizar los recursos de acuerdo con necesidades administrativas, operativas y de delegación¹⁴.

Los controladores de dominio son los servidores encargados de almacenar la base de datos del directorio y proporcionar servicios de autenticación y autorización. Además, Active Directory se apoya en DNS para la localización de servicios y en Kerberos como

¹³Microsoft, *Active Directory Domain Services Overview*, Consultado en junio de 2026, 2025. dirección: <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/get-started/virtual-dc/active-directory-domain-services-overview>

¹⁴Microsoft, *Understanding the Active Directory Logical Model*, Consultado en junio de 2026, 2025. dirección: <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/understanding-the-active-directory-logical-model>

mecanismo principal de autenticación dentro de dominios Windows. Microsoft documenta Kerberos como el protocolo utilizado para verificar la identidad de usuarios y hosts en entornos Windows Server¹⁵.

En el laboratorio, estos componentes se simplifican mediante un único controlador de dominio, denominado DC01, y una estación de trabajo integrada en el dominio, denominada DEV01. Esta aproximación permite reproducir los elementos esenciales de un entorno corporativo sin incrementar excesivamente la complejidad del despliegue.

2.9.2 Usuarios, grupos y permisos

La gestión de permisos dentro de Active Directory se basa principalmente en cuentas de usuario, cuentas de equipo y grupos de seguridad. Los grupos permiten agrupar identidades y asignar permisos de forma centralizada sobre recursos compartidos, simplificando la administración frente a la asignación individual de permisos¹⁶.

Este modelo facilita la gestión de entornos corporativos, pero también introduce riesgos cuando existen configuraciones incorrectas, privilegios excesivos o pertenencias indebidas a grupos administrativos. Microsoft identifica determinadas cuentas y grupos privilegiados de Active Directory como elementos especialmente sensibles, ya que disponen de permisos elevados para realizar acciones administrativas sobre el dominio y los sistemas unidos a él¹⁷.

En el contexto del laboratorio, la existencia de diferentes usuarios, grupos y niveles de privilegio permite simular escenarios en los que un atacante obtiene credenciales válidas y las reutiliza para acceder a otros sistemas, enumerar recursos o realizar movimiento lateral dentro de la infraestructura.

2.10 Protocolos y servicios utilizados

Diversos protocolos de red desempeñan un papel fundamental dentro de los entornos Windows modernos y suelen constituir objetivos habituales durante las fases de enumeración y post-explotación.

En este laboratorio destacan especialmente los servicios asociados a Active Directory, DNS, SMB y WinRM. Estos protocolos permiten reproducir operaciones habituales de una

¹⁵Microsoft, *Kerberos Authentication Overview in Windows Server*, Consultado en junio de 2026, 2025. dirección: <https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-authentication-overview>

¹⁶Microsoft, *Active Directory Security Groups*, Consultado en junio de 2026, 2025. dirección: <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/understand-security-groups>

¹⁷Microsoft, *Active Directory Privileged Accounts and Groups Guide*, Consultado en junio de 2026, 2025. dirección: <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/appendix-b--privileged-accounts-and-groups-in-active-directory>

red corporativa, como la resolución de nombres, la autenticación centralizada, la compartición de recursos y la administración remota de sistemas. Al mismo tiempo, proporcionan una superficie de análisis relevante para estudiar técnicas de enumeración, abuso de credenciales y movimiento lateral.

Desde el punto de vista ofensivo, estos servicios resultan relevantes porque pueden proporcionar información sobre usuarios, equipos, recursos compartidos o mecanismos de acceso remoto. Por ello, su presencia en el laboratorio permite conectar la parte teórica de la infraestructura Windows con los escenarios prácticos de explotación desarrollados posteriormente.

2.10.1 SMB

Server Message Block (SMB) es un protocolo de compartición de archivos utilizado en entornos Windows para acceder a ficheros, impresoras y otros recursos a través de la red. Microsoft lo describe como un protocolo de uso compartido de archivos que permite a las aplicaciones leer, crear y actualizar archivos en servidores remotos¹⁸.

Su amplia utilización en redes corporativas lo convierte en una fuente importante de información durante las fases de reconocimiento y enumeración. A través de SMB pueden identificarse recursos compartidos, permisos de acceso, nombres de equipos o información útil para fases posteriores del ataque.

En el contexto del laboratorio, SMB permite simular la compartición de recursos internos dentro de la infraestructura Windows y sirve como superficie de análisis durante las fases de enumeración y movimiento lateral.

2.10.2 WinRM

Windows Remote Management (WinRM) es la implementación de Microsoft del protocolo WS-Management, diseñado para permitir la administración remota de sistemas Windows mediante un protocolo interoperable y compatible con distintos entornos¹⁹.

En entornos corporativos, WinRM permite ejecutar tareas de administración remota y gestionar equipos Windows de forma centralizada. Desde una perspectiva ofensiva, cuando un atacante dispone de credenciales válidas, este servicio puede utilizarse para obtener acceso remoto interactivo a sistemas comprometidos y ejecutar comandos sobre ellos.

Dentro del laboratorio, WinRM se utiliza para representar un mecanismo de adminis-

¹⁸Microsoft, *What is SMB File Sharing for Windows and Windows Server?* Consultado en junio de 2026, 2025. dirección: <https://learn.microsoft.com/en-us/windows-server/storage/file-server/file-server-smb-overview>

¹⁹Microsoft, *Windows Remote Management*, Consultado en junio de 2026, 2025. dirección: <https://learn.microsoft.com/en-us/windows/win32/winrm/portal>

tración remota habitual en infraestructuras Windows. Su inclusión permite estudiar cómo las credenciales obtenidas durante fases anteriores pueden emplearse para acceder a equipos internos y avanzar en la cadena de ataque.

2.11 Movimiento lateral en entornos Windows

El movimiento lateral engloba el conjunto de técnicas utilizadas por un atacante para desplazarse entre diferentes sistemas dentro de una infraestructura comprometida. MITRE ATT&CK define esta táctica como el conjunto de técnicas utilizadas para entrar y controlar sistemas remotos dentro de una red²⁰.

Estas técnicas suelen apoyarse en credenciales obtenidas previamente, relaciones de confianza existentes entre equipos, servicios de administración remota o configuraciones inseguras presentes en el dominio. En entornos Windows, protocolos como SMB y WinRM pueden desempeñar un papel relevante, ya que permiten acceder a recursos compartidos o ejecutar acciones de administración remota.

En entornos Active Directory, el movimiento lateral constituye una fase crítica de la intrusión. Permite al atacante progresar desde sistemas de bajo privilegio hacia recursos de mayor criticidad, como estaciones de trabajo internas, servidores corporativos o controladores de dominio. Por este motivo, el laboratorio incorpora una infraestructura Windows que permite reproducir este tipo de técnicas en un entorno controlado.

²⁰MITRE Corporation, *Lateral Movement, Tactic TA0008 - Enterprise*, Consultado en junio de 2026, 2025. dirección: <https://attack.mitre.org/tactics/TA0008/>

Capítulo 3

Gestión y metodología del proyecto

3.1 Metodología de desarrollo

El desarrollo del proyecto se ha realizado siguiendo una metodología incremental e iterativa. Este enfoque ha permitido construir el laboratorio de forma progresiva, validando cada componente antes de incorporar nuevas funcionalidades o escenarios de ataque.

En una primera fase se diseñó la arquitectura general del laboratorio y se desplegó la infraestructura básica compuesta por una máquina atacante y un servidor web vulnerable. Una vez validado el funcionamiento del entorno inicial, se incorporaron nuevos elementos con el objetivo de aumentar el realismo del escenario, incluyendo una red interna segmentada y una infraestructura Windows basada en Active Directory.

Posteriormente se implementaron las vulnerabilidades presentes en la aplicación web y se desarrollaron los distintos escenarios de explotación. Cada fase fue sometida a pruebas de validación para garantizar la estabilidad del entorno y asegurar la correcta integración de los diferentes componentes.

Este enfoque permitió identificar incidencias de forma temprana, simplificar las tareas de depuración y facilitar la evolución progresiva del laboratorio hasta alcanzar la arquitectura final propuesta.

3.2 Planificación del proyecto

La ejecución del proyecto se dividió en varias fases que permitieron abordar de forma estructurada las diferentes tareas necesarias para la construcción del laboratorio.

1. Análisis de requisitos y definición de objetivos.

En esta fase se identificaron las necesidades del proyecto, se definieron los objetivos generales y específicos del laboratorio y se establecieron los requisitos funcionales y no funcionales que debía cumplir la solución final.

2. Diseño de la arquitectura del laboratorio.

Se diseñó la estructura general del entorno vulnerable, definiendo los sistemas que formarían parte de la infraestructura, la segmentación de red, los servicios necesarios y las relaciones entre los distintos componentes. La máquina atacante queda

fuera del despliegue del laboratorio y deberá ser preparada por el usuario mediante Kali Linux, Parrot OS u otra distribución equivalente.

3. Despliegue de la infraestructura virtual vulnerable.

Se procedió a la creación y configuración de las máquinas virtuales que componen el laboratorio vulnerable, incluyendo el servidor web, el controlador de dominio y la estación de trabajo corporativa.

4. Desarrollo de la aplicación web vulnerable.

Se implementó una aplicación web orientada a simular un portal corporativo realista, incorporando funcionalidades habituales de gestión de usuarios, clientes, empleados y tickets.

5. Implementación de vulnerabilidades y escenarios de ataque.

Se introdujeron vulnerabilidades de forma controlada siguiendo las categorías definidas por OWASP Top 10 y se diseñaron distintos escenarios de explotación que permitieran encadenar varias fases de ataque.

6. Integración de Active Directory y servicios internos.

Se desplegó una infraestructura Windows basada en Active Directory para simular una red corporativa interna y permitir la ejecución de técnicas de enumeración, pivoting y movimiento lateral.

7. Automatización del despliegue.

Se desarrollaron scripts y procedimientos automatizados destinados a simplificar la instalación, configuración y puesta en marcha del laboratorio vulnerable, mejorando su reproducibilidad.

8. Validación y documentación del entorno.

Finalmente, se verificó el correcto funcionamiento de todos los componentes mediante diferentes pruebas de explotación desde una máquina atacante externa y se elaboró la documentación técnica necesaria para facilitar su despliegue y utilización.

La planificación se realizó de forma flexible, permitiendo adaptar el alcance de determinadas tareas a medida que evolucionaba el laboratorio y se identificaban nuevas oportunidades de mejora.

3.3 Recursos utilizados

Para el desarrollo del proyecto se han empleado diferentes recursos hardware y software destinados al despliegue de la infraestructura virtual, el desarrollo de la aplicación vulnerable.

3.3.1 Hardware

El laboratorio está diseñado para ejecutarse sobre un equipo anfitrión capaz de virtualizar varias máquinas de forma simultánea. Al tratarse de un entorno compuesto por varios sistemas independientes, el recurso más relevante es la memoria RAM disponible, seguida del número de núcleos de CPU y del espacio de almacenamiento reservado para los discos virtuales.

La infraestructura vulnerable desplegada está compuesta por tres máquinas virtuales principales: un servidor Ubuntu Server utilizado como servidor web vulnerable, un controlador de dominio Windows Server 2012 denominado DC01 y una estación de trabajo Windows 7 denominada DEV01. Estas tres máquinas constituyen el laboratorio.

La máquina atacante no forma parte de la infraestructura vulnerable como tal, ya que puede plantearse de dos formas distintas. En primer lugar, si el equipo anfitrión utiliza un sistema operativo orientado a seguridad ofensiva, como Kali Linux o Parrot OS, el propio host puede actuar como máquina atacante. En segundo lugar, si el equipo anfitrión utiliza un sistema operativo de propósito general, como Windows, Linux o macOS, será necesario preparar una máquina virtual atacante adicional con Kali Linux, Parrot OS u otra distribución equivalente.

Los recursos mínimos recomendados para las máquinas virtuales del laboratorio son los siguientes:

Tabla 2 Recursos mínimos recomendados para las máquinas virtuales del laboratorio

Máquina Virtual	CPU	RAM	Disco
Servidor web Ubuntu Server 22.04	2 cores	3 GB	40 GB
DC01 Windows Server 2012	2 cores	4 GB	60 GB
DEV01 Windows 7	2 cores	3 GB	40 GB
Máquina atacante externa (opcional)	4 cores	3 GB	40 GB

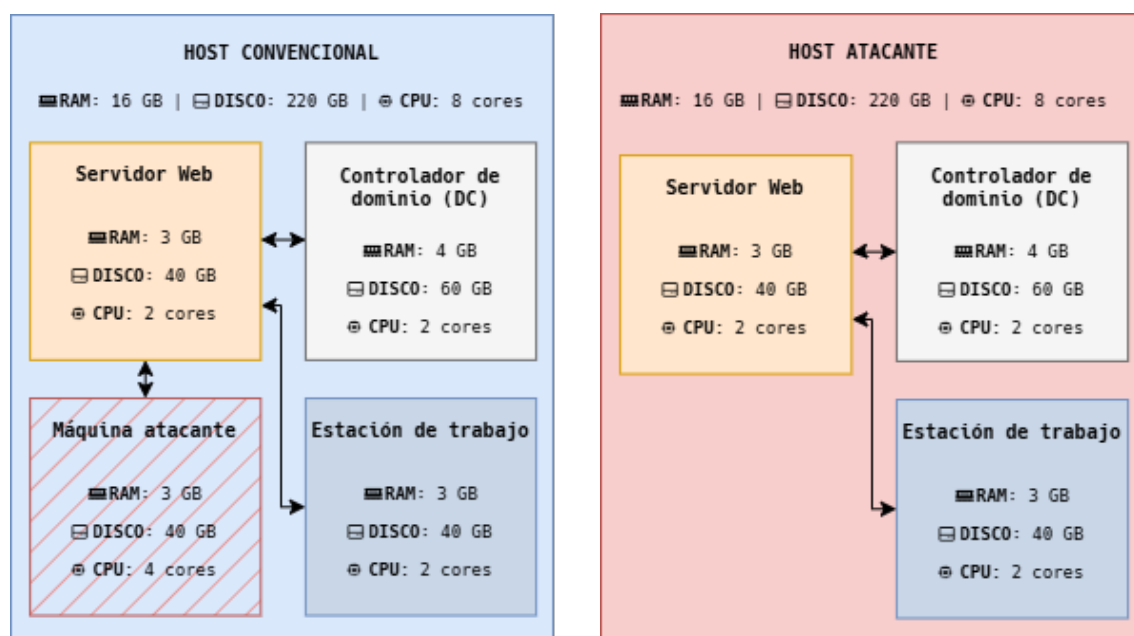
A partir de estos valores, el equipo anfitrión debería disponer, como mínimo, de 8

núcleos de CPU, 16 GB de memoria RAM y al menos 200 GB de espacio libre en disco para ejecutar el laboratorio con cierta fluidez. No obstante, se recomienda contar con 32 GB de RAM cuando se desee trabajar simultáneamente con todas las máquinas encendidas y realizar pruebas de explotación de forma cómoda.

En caso de que el usuario no disponga previamente de una máquina atacante, será necesario preparar una máquina adicional con una distribución orientada a seguridad ofensiva. Para este sistema se recomienda asignar 4 núcleos de CPU, 3 GB de RAM y 40 GB de disco, aunque estos recursos pueden variar en función de las herramientas instaladas y del uso previsto.

Por tanto, para un despliegue completo de la infraestructura vulnerable se recomienda que el equipo anfitrión disponga de las siguientes características:

- Procesador de 8 núcleos o superior con soporte de virtualización por hardware.
- 16 GB de memoria RAM recomendados.
- 150 GB de espacio libre en disco como mínimo.
- Capacidad para ejecutar VMware Workstation u otra plataforma de virtualización.



(a) Equipo anfitrión convencional con máquina atacante externa.

(b) Equipo anfitrión actuando como máquina atacante.

Figura 4 Escenarios de despliegue del laboratorio: con máquina atacante externa y utilizando el propio equipo anfitrión como atacante.

En el caso del despliegue realizado durante el desarrollo del proyecto, el tamaño real ocupado por las máquinas virtuales fue el siguiente:

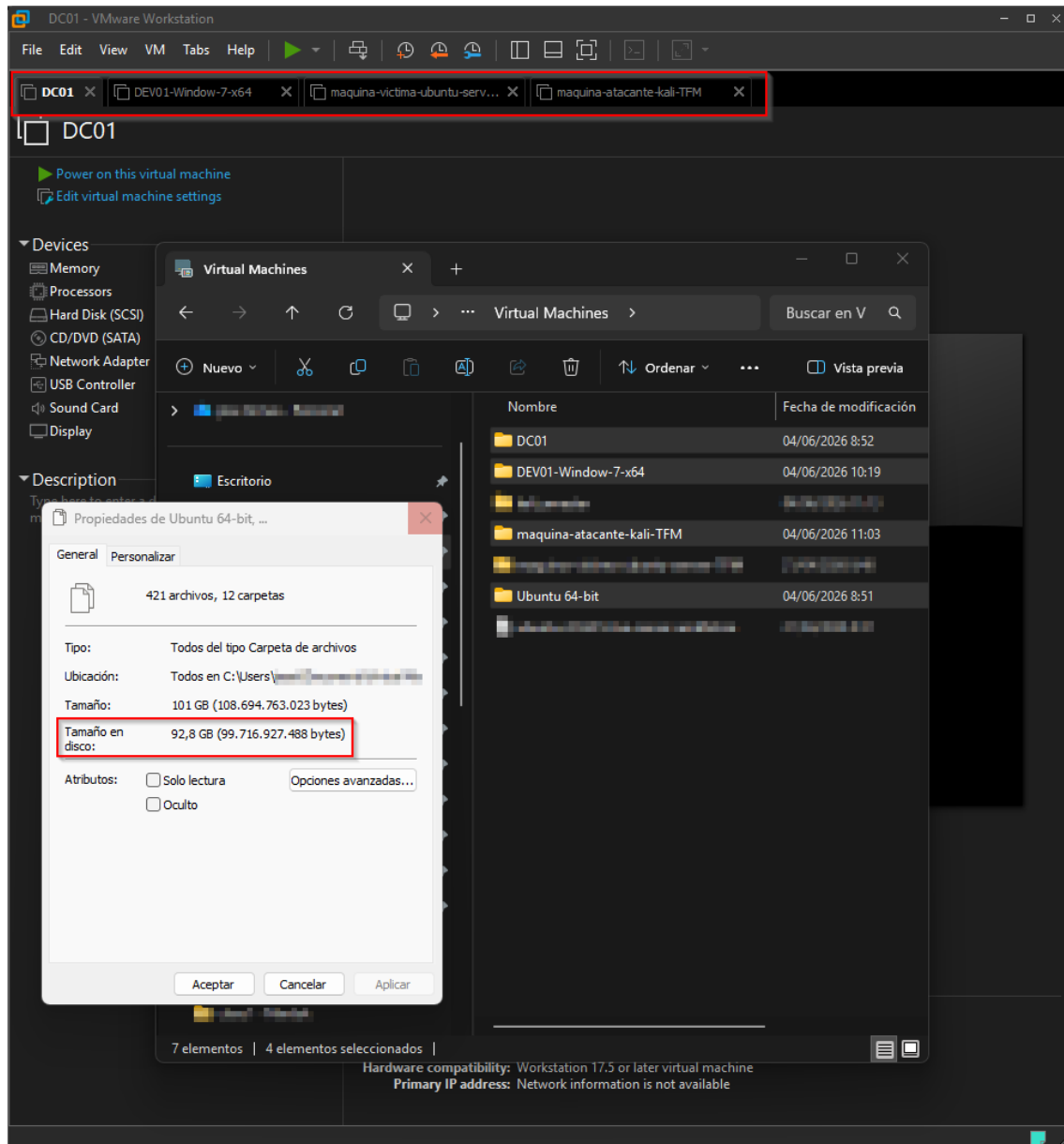


Figura 5 Tamaño aproximado del laboratorio desplegado en el equipo anfitrión, incluyendo máquina atacante.

Aunque la capacidad máxima asignada a las máquinas virtuales de la infraestructura vulnerable asciende a 140 GB, VMware utiliza discos virtuales de crecimiento dinámico, por lo que el espacio ocupado en disco depende del uso real de cada máquina.

Durante las pruebas realizadas, el laboratorio completo desplegado ocupó aproximadamente 93 GB de almacenamiento en el equipo anfitrión. Por este motivo, se recomienda

disponer de al menos 150 GB de espacio libre para desplegar la infraestructura vulnerable con margen suficiente para actualizaciones, instantáneas y crecimiento de los datos.

En caso de utilizar una máquina atacante externa virtualizada, la capacidad máxima asignada al conjunto completo ascendería a aproximadamente 180 GB. Para este escenario, se recomienda disponer de alrededor de 200 GB de espacio libre en el equipo anfitrión.

3.3.2 Software

Para el desarrollo del proyecto se utilizaron diferentes sistemas operativos, servicios y herramientas destinados al despliegue del laboratorio, la ejecución de los componentes vulnerables y la gestión de la infraestructura virtual.

En primer lugar, se empleó *VMware Workstation Pro* como plataforma de virtualización, permitiendo crear y gestionar las distintas máquinas virtuales que forman parte del laboratorio. Esta plataforma facilita la configuración de redes virtuales, la asignación de recursos hardware y el uso de instantáneas para restaurar el entorno durante las pruebas.

En relación con el servidor web vulnerable, se utilizó *Ubuntu Server 22.04* como sistema operativo base. Sobre este sistema se desplegaron los servicios necesarios para alojar la aplicación web, incluyendo *Apache HTTP Server*, *PHP* y *MySQL*. Además, se emplearon *Docker* y *Docker Compose* para facilitar el despliegue de los contenedores asociados al laboratorio y mejorar la reproducibilidad del entorno.

La infraestructura de directorio activo se implementó mediante *Windows Server 2012*, configurado como controlador de dominio principal del laboratorio. Este sistema proporciona los servicios de *Active Directory Domain Services*, DNS, SMB y WinRM, necesarios para simular un entorno corporativo Windows. Como estación de trabajo integrada en el dominio se utilizó *Windows 7*, representando un equipo interno accesible desde la red corporativa.

Por último, para la gestión del código fuente y la documentación se utilizaron *Git* y *GitHub*, permitiendo mantener un control de versiones del proyecto, organizar los scripts de despliegue y documentar la evolución del laboratorio.

Capítulo 4

Análisis del entorno y requisitos

El diseño de un laboratorio de ciberseguridad requiere definir previamente los requisitos que debe satisfacer el entorno, así como los escenarios de amenaza que se desean reproducir. Este análisis permite establecer una base sólida para el desarrollo de la infraestructura vulnerable y garantizar que los escenarios de ataque implementados resulten representativos de situaciones reales.

El laboratorio desarrollado en este proyecto está orientado a la simulación de una pequeña organización con una infraestructura híbrida compuesta por servicios Linux y Windows. El objetivo principal consiste en proporcionar un entorno controlado donde sea posible reproducir técnicas de reconocimiento, explotación, escalada de privilegios y movimiento lateral utilizadas habitualmente durante ejercicios de Red Team y pruebas de penetración.

4.1 Requisitos funcionales

Los requisitos funcionales describen las capacidades que debe proporcionar el laboratorio para cumplir los objetivos definidos durante el desarrollo del proyecto.

1. Simulación de un entorno corporativo realista.

El laboratorio debe reproducir una infraestructura similar a la que podría encontrarse en una pequeña o mediana empresa, incluyendo servicios web, sistemas Windows y mecanismos de autenticación centralizada.

2. Despliegue reproducible.

Todos los componentes del laboratorio deben poder instalarse y configurarse mediante procedimientos documentados y automatizados que permitan recrear el entorno en distintos equipos anfitriones.

3. Ejecución de escenarios de ataque completos.

El entorno debe permitir la realización de cadenas de ataque que incluyan reconocimiento, explotación, escalada de privilegios, persistencia y movimiento lateral.

4. Incorporación de vulnerabilidades reales.

La aplicación web vulnerable debe contener fallos representativos de las categorías definidas por OWASP Top 10, permitiendo su explotación de forma controlada.

5. Integración con Active Directory.

El laboratorio debe incorporar una infraestructura Windows basada en Active Directory que permita realizar ejercicios de enumeración, autenticación y movimiento lateral.

6. Aislamiento del entorno.

La infraestructura debe ejecutarse en una red virtual aislada que impida afectar a sistemas externos durante las pruebas.

7. Documentación de los escenarios de explotación.

Cada vulnerabilidad implementada debe estar acompañada de una guía de explotación y mitigación que facilite su utilización con fines docentes.

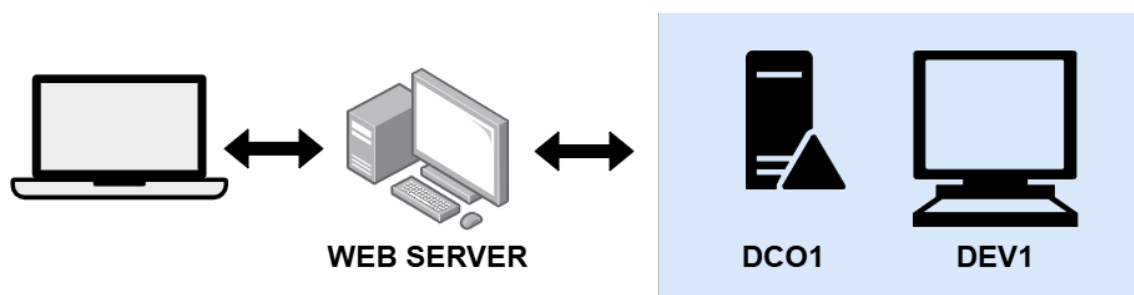


Figura 6 Diagrama general de alto nivel del laboratorio, mostrando los principales componentes y su interconexión.

4.2 Requisitos no funcionales

Además de los requisitos funcionales, el laboratorio debe satisfacer una serie de requisitos no funcionales relacionados con la calidad, mantenibilidad y usabilidad de la solución.

1. Reproducibilidad.

El despliegue debe producir resultados consistentes independientemente del equipo anfitrión utilizado.

2. Escalabilidad.

La arquitectura debe permitir incorporar nuevas vulnerabilidades y escenarios de ataque sin necesidad de rediseñar la infraestructura existente.

3. Mantenibilidad.

Los distintos componentes deben encontrarse correctamente documentados para facilitar futuras modificaciones y ampliaciones.

4. Portabilidad.

El laboratorio debe poder ejecutarse sobre distintas plataformas de virtualización compatibles con VMware Workstation.

5. Seguridad operacional.

La infraestructura vulnerable debe permanecer aislada del entorno de producción y de redes externas.

6. Consumo razonable de recursos.

Los requisitos hardware deben mantenerse dentro de unos márgenes asumibles para equipos domésticos o académicos.

Tabla 3 Resumen de requisitos no funcionales

Categoría	Objetivo
Reproducibilidad	Permitir recrear el entorno de forma consistente en diferentes equipos anfitriones.
Escalabilidad	Facilitar la incorporación de nuevos escenarios de ataque y vulnerabilidades.
Mantenibilidad	Simplificar futuras modificaciones y ampliaciones del laboratorio.
Portabilidad	Permitir la ejecución en diferentes entornos de virtualización.
Seguridad	Mantener el aislamiento respecto a redes externas.
Rendimiento	Funcionar correctamente con recursos hardware moderados.

4.3 Análisis de amenazas y superficie de ataque

El laboratorio se ha diseñado para representar una organización expuesta a amenazas habituales presentes en entornos corporativos actuales. Para ello se han identificado los

principales activos, vectores de entrada y superficies de ataque susceptibles de ser comprometidas por un atacante externo.

La superficie de ataque principal se encuentra representada por la aplicación web vulnerable publicada en el servidor Ubuntu. Este sistema constituye el punto inicial de acceso al entorno y concentra la mayor parte de las vulnerabilidades implementadas.

Una vez comprometido el servidor web, el atacante puede acceder a información sensible, credenciales almacenadas incorrectamente o mecanismos inseguros de configuración que permiten ampliar el alcance del ataque.

La presencia de una infraestructura Active Directory introduce una segunda superficie de ataque relacionada con la autenticación, la gestión de privilegios y el movimiento lateral dentro de la red interna.

Las amenazas consideradas durante el diseño del laboratorio incluyen:

- Explotación de vulnerabilidades web.
- Robo de credenciales.
- Escalada local de privilegios.
- Movimiento lateral entre sistemas.
- Persistencia en sistemas comprometidos.
- Acceso no autorizado a información sensible.
- Abuso de configuraciones inseguras.

Tabla 4 Activos y vectores de ataque considerados

Activo	Amenaza principal	Impacto
Aplicación web	Explotación de vulnerabilidades OWASP	Acceso inicial al entorno
Servidor Ubuntu	Escalada de privilegios	Compromiso total del sistema
Estación DEV01	Movimiento lateral	Acceso a recursos internos
Active Directory	Robo de credenciales	Control del dominio
Base de datos	Acceso no autorizado	Exposición de información sensible

La Tabla 4 resume los principales activos presentes en el laboratorio y las amenazas asociadas a cada uno de ellos. No obstante, estas amenazas no deben entenderse como eventos aislados, sino como etapas que pueden encadenarse para construir una intrusión completa.

La Figura 7 representa una posible cadena de ataque sobre la infraestructura diseñada. El escenario parte de la explotación de vulnerabilidades presentes en la aplicación web, continúa con la obtención de acceso al servidor Ubuntu y culmina con el compromiso de los sistemas internos y de la infraestructura Active Directory. Este flujo permite reproducir de forma controlada las distintas fases que suelen observarse en ejercicios de Red Team y pruebas de penetración sobre entornos corporativos.

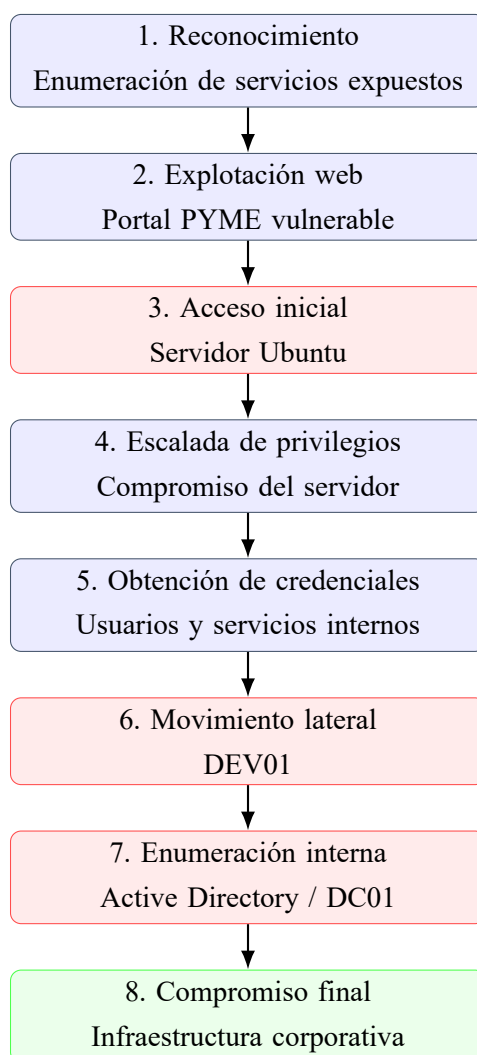


Figura 7 Flujo general de ataque planteado en el laboratorio.

4.4 Justificación del uso de OWASP y MITRE ATT&CK

La selección de OWASP Top 10 y MITRE ATT&CK como marcos de referencia responde a la necesidad de fundamentar el laboratorio sobre estándares ampliamente aceptados dentro del ámbito de la ciberseguridad.

OWASP Top 10 constituye una de las referencias más utilizadas para la identificación y clasificación de vulnerabilidades presentes en aplicaciones web. Su adopción permite incorporar al laboratorio fallos representativos que reflejan problemas observados de forma recurrente en entornos reales.

Por su parte, MITRE ATT&CK proporciona una base de conocimiento estructurada sobre tácticas, técnicas y procedimientos empleados por atacantes reales durante distintas fases de una intrusión. Este marco facilita la modelización de cadenas de ataque completas y permite relacionar cada escenario implementado con técnicas reconocidas por la comunidad de seguridad.

La combinación de ambos enfoques permite cubrir tanto la perspectiva defensiva asociada a las vulnerabilidades como la perspectiva ofensiva relacionada con las técnicas de explotación utilizadas para comprometer los sistemas.

Tabla 5 Relación entre componentes del laboratorio y marcos de referencia

Elemento	OWASP	MITRE ATT&CK
Aplicación web vulnerable	Sí	Parcial
Escalada de privilegios	No	Sí
Movimiento lateral	No	Sí
Credenciales inseguras	Sí	Sí
Persistencia	No	Sí
Cadena completa de ataque	Sí	Sí

Capítulo 5

Diseño del laboratorio

El diseño del laboratorio constituye uno de los elementos fundamentales del proyecto, ya que determina la forma en la que se desarrollarán los distintos escenarios de ataque y condiciona la capacidad del entorno para reproducir situaciones reales. El objetivo principal ha sido construir una infraestructura que simule una pequeña organización con servicios expuestos a Internet y una red interna basada en tecnologías Microsoft, permitiendo encadenar diferentes fases de una intrusión de forma controlada.

Para ello se ha optado por una arquitectura compuesta por varios sistemas virtualizados que representan distintos activos de una empresa. Esta aproximación permite separar los diferentes servicios, facilitar la gestión del entorno y reproducir de forma más realista las técnicas utilizadas habitualmente durante ejercicios de Red Team y pruebas de penetración.

La infraestructura resultante combina sistemas Linux y Windows, servicios web, Active Directory y estaciones de trabajo corporativas, proporcionando múltiples superficies de ataque y permitiendo la ejecución de escenarios que abarcan desde la explotación inicial de una vulnerabilidad web hasta el compromiso completo de una infraestructura interna.

5.1 Arquitectura general

La arquitectura general del laboratorio ha sido diseñada siguiendo una estructura escalonada que obliga al atacante a progresar a través de distintas fases de compromiso. De esta forma, el acceso a los sistemas internos no es directo, sino que requiere explotar vulnerabilidades, obtener credenciales y realizar movimientos laterales similares a los que se producen en ataques reales.

El entorno está compuesto por tres máquinas virtuales principales que constituyen la infraestructura vulnerable:

- Un servidor Ubuntu Server 22.04 encargado de alojar la aplicación web vulnerable.
- Un controlador de dominio Windows Server 2012 denominado DC01.
- Una estación de trabajo Windows 7 denominada DEV01.

Estas máquinas representan los principales elementos que pueden encontrarse en una pequeña o mediana empresa y permiten implementar escenarios de ataque progresivos

que combinan vulnerabilidades web con técnicas de post-explotación sobre entornos Windows.

La máquina atacante no forma parte del laboratorio vulnerable como tal. Dependiendo del escenario de despliegue, el usuario puede utilizar directamente el sistema anfitrión como plataforma de ataque si dispone de una distribución especializada como Kali Linux o Parrot OS, o bien desplegar una máquina virtual adicional dedicada a tareas ofensivas.

El diseño busca mantener un equilibrio entre realismo y simplicidad. Por un lado, incorpora suficientes componentes para permitir escenarios complejos de explotación; por otro, evita una infraestructura excesivamente grande que dificultaría su despliegue en equipos domésticos o académicos.

5.1.1 Arquitectura física

Desde una perspectiva física, toda la infraestructura se ejecuta sobre un único equipo anfitrión utilizando VMware Workstation como plataforma de virtualización. Cada sistema se encuentra encapsulado en una máquina virtual independiente, permitiendo asignar recursos específicos a cada componente y facilitando la gestión del laboratorio.

La utilización de máquinas virtuales aporta varias ventajas relevantes para este proyecto. En primer lugar, permite mantener completamente aislado el entorno vulnerable respecto al sistema anfitrión. En segundo lugar, facilita la creación de instantáneas que permiten restaurar rápidamente el estado del laboratorio después de una explotación o durante las tareas de validación. Finalmente, mejora la portabilidad del proyecto, ya que las máquinas pueden trasladarse entre distintos equipos sin necesidad de repetir todo el proceso de instalación.

Cada máquina virtual dispone de una función específica dentro de la infraestructura. El servidor Ubuntu aloja los servicios expuestos al exterior y constituye el principal punto de entrada para el atacante. El controlador de dominio centraliza la autenticación y la gestión de usuarios dentro de la red corporativa, mientras que la estación de trabajo representa un equipo interno susceptible de ser comprometido mediante técnicas de movimiento lateral.

Esta distribución permite reproducir de forma realista la separación habitual entre sistemas expuestos y sistemas internos presente en muchas organizaciones.

5.1.2 Arquitectura lógica

A nivel lógico, la infraestructura se divide en varios niveles de acceso que representan las distintas fases de compromiso que debe superar un atacante.

El primer nivel está formado por los servicios accesibles inicialmente desde la red del atacante. Dentro de este nivel se encuentra el portal web vulnerable desplegado sobre

Ubuntu Server, que actúa como punto de entrada principal al laboratorio.

El segundo nivel corresponde a la infraestructura interna basada en Active Directory. Esta red contiene los sistemas corporativos que no son accesibles directamente desde el exterior y que requieren un compromiso previo para poder ser alcanzados. El acceso a estos sistemas obliga al atacante a obtener credenciales válidas, realizar tareas de enumeración y aprovechar relaciones de confianza existentes dentro de la infraestructura.

Finalmente, el tercer nivel está constituido por los recursos y servicios internos que permiten desarrollar técnicas de post-explotación, persistencia y movimiento lateral. Este diseño facilita la construcción de cadenas de ataque progresivas donde cada vulnerabilidad explotada proporciona acceso a nuevos recursos y aumenta el alcance del compromiso.

La separación lógica entre estos niveles no solo mejora el realismo del laboratorio, sino que también permite analizar con mayor claridad las distintas etapas de un ataque y estudiar cómo pequeños fallos de seguridad pueden combinarse para producir un compromiso completo de la organización.

5.1.3 Segmentación de red

La segmentación de red constituye uno de los mecanismos principales utilizados para aumentar el realismo del laboratorio y controlar las comunicaciones entre los distintos sistemas.

En lugar de conectar todas las máquinas a una misma red virtual, se han definido diferentes segmentos que permiten simular la separación habitual existente entre servicios públicos e infraestructura interna. Esta división obliga al atacante a utilizar técnicas de pivoting y movimiento lateral para progresar dentro del entorno.

El servidor Ubuntu actúa como punto intermedio entre la red utilizada por el atacante y la infraestructura interna. Una vez comprometido este sistema, es posible acceder a recursos que inicialmente no eran visibles, reproduciendo así escenarios habituales de intrusión corporativa.

Además de mejorar el realismo de los escenarios de ataque, esta segmentación permite controlar con precisión qué servicios son accesibles desde cada zona de la infraestructura y facilita la implementación de ejercicios relacionados con enumeración de red, descubrimiento de servicios internos y explotación de relaciones de confianza.

La estructura de red adoptada proporciona un equilibrio adecuado entre complejidad y facilidad de despliegue, permitiendo reproducir técnicas avanzadas sin incrementar excesivamente los requisitos hardware del laboratorio.

5.1.4 Diagrama completo de infraestructura

La Figura ?? muestra la arquitectura final del laboratorio y las relaciones existentes entre todos sus componentes.

En ella pueden observarse las máquinas virtuales que forman parte de la infraestructura, los distintos segmentos de red utilizados, los servicios desplegados y los flujos de comunicación necesarios para la ejecución de los escenarios de ataque planteados durante el proyecto.

Este diagrama resume la arquitectura completa del laboratorio y sirve como referencia para comprender las distintas fases de explotación que se desarrollarán en los capítulos posteriores.

5.2 Diseño del servidor vulnerable

El servidor vulnerable constituye el elemento central del laboratorio y representa el principal punto de entrada para los escenarios de ataque implementados. Su diseño persigue reproducir las características de un servidor corporativo real que aloja una aplicación web accesible por los usuarios de la organización.

Para su implementación se ha seleccionado Ubuntu Server 22.04 como sistema operativo base debido a su estabilidad, amplia documentación y elevada adopción dentro de entornos empresariales. Sobre este sistema se despliegan los distintos servicios necesarios para ejecutar la aplicación vulnerable y proporcionar funcionalidades similares a las que podrían encontrarse en una pequeña empresa.

El servidor no se limita únicamente a alojar una aplicación web vulnerable, sino que también incorpora configuraciones inseguras, credenciales expuestas y distintos elementos destinados a facilitar la construcción de cadenas de ataque complejas. De esta forma, una vulnerabilidad inicial puede convertirse en el punto de partida para comprometer otros sistemas de la infraestructura.

El diseño del servidor se ha realizado intentando mantener un equilibrio entre realismo y valor didáctico. Las vulnerabilidades introducidas son representativas de problemas observados frecuentemente en entornos reales, pero han sido adaptadas para garantizar que puedan ser explotadas de forma controlada dentro del laboratorio.

5.2.1 Stack tecnológico

La aplicación vulnerable se apoya sobre una pila tecnológica basada en componentes ampliamente utilizados en entornos reales. La selección de estas tecnologías permite que los escenarios desarrollados resulten representativos de situaciones que pueden encontrar-

se habitualmente durante auditorías de seguridad o ejercicios de Red Team.

El sistema operativo utilizado es Ubuntu Server 22.04. Sobre él se despliegan los servicios web necesarios para alojar la aplicación vulnerable y la base de datos asociada.

Para simplificar el despliegue y mejorar la reproducibilidad del entorno se ha optado por utilizar Docker y Docker Compose. Esta aproximación permite encapsular los distintos componentes de la aplicación y garantizar que el comportamiento del laboratorio sea consistente independientemente del equipo anfitrión utilizado.

La lógica de negocio del portal se ha desarrollado utilizando PHP, mientras que el almacenamiento de la información se realiza mediante MySQL. Finalmente, Apache HTTP Server actúa como servidor web encargado de atender las peticiones realizadas por los usuarios.

Tabla 6 Stack tecnológico utilizado en el servidor vulnerable

Componente	Función
Ubuntu Server 22.04	Sistema operativo base
Docker	Contenerización de servicios
Docker Compose	Orquestación de contenedores
Apache HTTP Server	Servidor web
PHP	Lógica de aplicación
MySQL	Base de datos

5.2.2 Portal PYME vulnerable

Con el objetivo de evitar el uso de aplicaciones deliberadamente inseguras y aumentar el realismo del laboratorio, se desarrolló una aplicación web propia denominada *Portal PYME*.

La aplicación simula un sistema de gestión utilizado por una pequeña organización y proporciona funcionalidades similares a las que pueden encontrarse en numerosos entornos empresariales. Entre ellas destacan la gestión de usuarios, la administración de clientes, el control de empleados y la gestión de incidencias mediante un sistema de tickets.

A diferencia de laboratorios clásicos como DVWA o Mutillidae, el portal desarrollado para este proyecto intenta presentar una apariencia más cercana a una aplicación corporativa real. Esto permite que las vulnerabilidades implementadas se integren de forma natural

dentro del flujo de funcionamiento de la aplicación y facilita la construcción de escenarios de ataque más creíbles.

El portal constituye el principal punto de entrada al laboratorio y concentra la mayor parte de las vulnerabilidades utilizadas durante los distintos ejercicios de explotación.

5.2.3 Vulnerabilidades implementadas

Las vulnerabilidades incorporadas en el laboratorio han sido seleccionadas tomando como referencia las categorías definidas por OWASP Top 10, así como errores de configuración y malas prácticas frecuentemente observadas durante auditorías de seguridad reales.

El objetivo no consiste únicamente en demostrar la explotación aislada de cada vulnerabilidad, sino permitir la construcción de cadenas de ataque completas donde una debilidad inicial proporcione acceso a nuevos recursos, credenciales o sistemas internos.

Durante el diseño del laboratorio se ha buscado que las vulnerabilidades se encuentren integradas de forma natural dentro del funcionamiento de la aplicación, evitando mecanismos artificiales que reduzcan el realismo del entorno. De esta forma, el atacante debe realizar tareas de reconocimiento, enumeración y análisis antes de identificar los vectores de explotación disponibles.

Además de las vulnerabilidades presentes en la aplicación web, el laboratorio incorpora configuraciones inseguras y mecanismos de escalada de privilegios tanto en el entorno Linux como en la infraestructura Windows, permitiendo reproducir diferentes fases de una intrusión real.

Tabla 7 Categorías de vulnerabilidades implementadas en el laboratorio

Categoría	Objetivo
Vulnerabilidades web	Obtener acceso inicial al entorno
Exposición de credenciales	Facilitar el acceso a otros sistemas
Escalada de privilegios Linux	Obtener control completo del servidor
Configuraciones inseguras	Aumentar la superficie de ataque
Movimiento lateral	Acceder a la infraestructura interna
Debilidades en Active Directory	Comprometer recursos corporativos

5.3 Diseño de la infraestructura Active Directory

La incorporación de una infraestructura Active Directory permite ampliar significativamente las posibilidades del laboratorio y reproducir escenarios de ataque que van más allá de la explotación inicial de una aplicación web.

En numerosos incidentes de seguridad reales, el compromiso de un servidor expuesto constituye únicamente la primera fase de la intrusión. Una vez obtenido acceso inicial, los atacantes suelen intentar acceder a sistemas internos, obtener credenciales corporativas y comprometer servicios de autenticación centralizados.

Con el objetivo de reproducir este tipo de situaciones, se ha diseñado una infraestructura Windows compuesta por un controlador de dominio y una estación de trabajo integrada en el dominio. Ambos sistemas permiten desarrollar ejercicios de enumeración, movimiento lateral, abuso de credenciales y post-explotación.

La arquitectura propuesta mantiene un nivel de complejidad suficiente para simular un entorno empresarial realista sin incrementar excesivamente los requisitos hardware necesarios para su ejecución.

5.3.1 DC01

DC01 constituye el controlador de dominio principal del laboratorio y representa el núcleo de la infraestructura Windows desplegada.

Este sistema se encuentra basado en Windows Server 2012 y proporciona los servicios necesarios para gestionar la autenticación, autorización y administración centralizada de usuarios y equipos. Desde este servidor se gestionan las cuentas de usuario, los grupos de seguridad, las políticas de dominio y diversos servicios internos necesarios para el funcionamiento de la organización simulada.

La elección de Windows Server 2012 responde a su amplia presencia histórica en entornos corporativos y a la disponibilidad de numerosas técnicas de ataque documentadas que permiten desarrollar escenarios de explotación realistas.

Desde la perspectiva ofensiva, DC01 constituye uno de los objetivos principales del laboratorio, ya que su compromiso permite acceder a información sensible y obtener control sobre el resto de sistemas integrados en el dominio.

5.3.2 DEV01

DEV01 representa una estación de trabajo corporativa integrada dentro del dominio gestionado por DC01.

Este sistema se encuentra basado en Windows 7 y simula el equipo utilizado por un

empleado de la organización. Su presencia dentro del laboratorio permite reproducir escenarios habituales de movimiento lateral y acceso a recursos internos tras comprometer otros sistemas de la infraestructura.

La estación de trabajo almacena información corporativa, credenciales y configuraciones que pueden resultar de interés para un atacante durante las fases posteriores de una intrusión.

La existencia de un equipo cliente integrado en Active Directory permite además evaluar las relaciones de confianza existentes dentro del dominio y reproducir técnicas de post-explotación ampliamente utilizadas en entornos Windows.

5.3.3 Usuarios y políticas

Con el objetivo de aumentar el realismo del laboratorio, se han definido distintos usuarios y grupos que representan perfiles habituales dentro de una pequeña organización.

La infraestructura incorpora cuentas administrativas y usuarios estándar con diferentes niveles de privilegio. Esta separación permite reproducir escenarios donde el atacante debe obtener credenciales adicionales para ampliar progresivamente el alcance de su compromiso.

Asimismo, se han configurado diferentes políticas de acceso y configuraciones de seguridad que permiten estudiar cómo determinados errores administrativos pueden facilitar el movimiento lateral o la escalada de privilegios dentro del dominio.

La distribución de permisos se ha diseñado intentando reflejar situaciones observadas frecuentemente en entornos reales, donde la acumulación de pequeños errores de configuración puede derivar en compromisos de gran impacto.

5.3.4 Servicios internos

Además de los mecanismos de autenticación proporcionados por Active Directory, la infraestructura incorpora diversos servicios internos destinados a aumentar el realismo del laboratorio.

Entre ellos destacan los servicios de resolución DNS, compartición de recursos mediante SMB y mecanismos de administración remota que permiten la gestión centralizada de los sistemas Windows.

Estos servicios resultan especialmente relevantes desde el punto de vista ofensivo, ya que suelen constituir una fuente importante de información durante las fases de enumeración y movimiento lateral.

Su presencia permite reproducir procedimientos habituales utilizados por los atacantes para identificar sistemas internos, descubrir recursos compartidos y obtener acceso a

información adicional sobre la infraestructura comprometida.

5.4 Diseño del escenario ofensivo

El laboratorio ha sido diseñado para permitir la ejecución de una cadena de ataque progresiva que reproduzca las distintas fases observadas habitualmente durante una intrusión real.

La secuencia comienza con actividades de reconocimiento dirigidas a identificar servicios expuestos y recopilar información sobre la organización simulada. Posteriormente, el atacante debe explotar una o varias vulnerabilidades presentes en la aplicación web para obtener acceso inicial al servidor Ubuntu.

Una vez comprometido el servidor, el escenario contempla la obtención de credenciales, la escalada de privilegios y el acceso a recursos internos que inicialmente no se encontraban disponibles.

Las fases posteriores incluyen tareas de enumeración sobre Active Directory, movimiento lateral entre sistemas y compromiso de recursos corporativos internos.

Este enfoque permite analizar de forma práctica cómo una vulnerabilidad aparentemente aislada puede convertirse en el punto de partida para comprometer una infraestructura completa.

5.5 Automatización y despliegue

Uno de los objetivos principales del proyecto consiste en garantizar que el laboratorio pueda desplegarse de forma sencilla y reproducible en distintos equipos anfitriones.

Para ello se han desarrollado mecanismos de automatización destinados a reducir las tareas manuales necesarias durante la instalación y configuración de la infraestructura. Esta aproximación minimiza los errores de despliegue y facilita la utilización del laboratorio por parte de otros usuarios.

La automatización abarca tanto el despliegue de los componentes de la aplicación web como la preparación del entorno vulnerable y la configuración inicial de determinados servicios.

5.5.1 Docker

Docker constituye uno de los elementos clave utilizados durante el desarrollo del laboratorio.

Su utilización permite encapsular los distintos servicios necesarios para ejecutar la aplicación vulnerable dentro de contenedores independientes, simplificando su instalación

y reduciendo las dependencias del sistema anfitrión.

Además de mejorar la reproducibilidad del entorno, Docker facilita las tareas de mantenimiento y permite desplegar rápidamente nuevas versiones del laboratorio sin necesidad de realizar modificaciones complejas sobre el sistema operativo base.

La combinación de Docker y Docker Compose permite definir toda la infraestructura necesaria mediante archivos de configuración fácilmente versionables y reutilizables.

5.5.2 Reproducibilidad del laboratorio

Con el objetivo de facilitar la distribución y reutilización del proyecto, se han desarrollado procedimientos documentados que permiten desplegar el laboratorio desde cero siguiendo una secuencia controlada de pasos.

La utilización de scripts de instalación, configuraciones automatizadas y contenedores facilita la recreación del entorno en diferentes equipos sin necesidad de realizar configuraciones manuales complejas.

Este enfoque resulta especialmente importante en entornos docentes, donde la capacidad para reproducir exactamente las mismas condiciones de trabajo constituye un requisito fundamental para garantizar la consistencia de las prácticas realizadas.

5.6 Repositorio y estructura del proyecto

Todo el material desarrollado durante el proyecto se encuentra organizado dentro de un repositorio Git estructurado por componentes funcionales.

La utilización de control de versiones permite mantener un historial completo de modificaciones, facilitar el desarrollo iterativo del laboratorio y simplificar la distribución de futuras actualizaciones.

La estructura del repositorio separa claramente los elementos relacionados con la infraestructura vulnerable, los scripts de automatización, la documentación técnica y los recursos necesarios para la explotación de los distintos escenarios de ataque.

Esta organización mejora la mantenibilidad del proyecto y facilita que otros usuarios puedan comprender rápidamente la finalidad de cada componente y desplegar el laboratorio siguiendo la documentación proporcionada.

Capítulo 6

Validación y explotación del laboratorio

El objetivo de esta fase consiste en validar el correcto funcionamiento de la infraestructura desarrollada y comprobar que los distintos escenarios de ataque definidos durante el diseño del laboratorio pueden ejecutarse de forma satisfactoria.

Para ello se llevaron a cabo diferentes ejercicios de explotación desde una máquina atacante externa basada en Kali Linux. Las pruebas realizadas permitieron verificar tanto las vulnerabilidades implementadas en la aplicación web como los mecanismos de escalada de privilegios, pivoting y movimiento lateral presentes en la infraestructura.

La validación se realizó siguiendo una secuencia progresiva que reproduce las fases habituales de una intrusión real, comenzando por el reconocimiento inicial del entorno y finalizando con el compromiso de la infraestructura Active Directory.

6.1 Metodología de pruebas

Las pruebas de validación se realizaron siguiendo una metodología inspirada en procesos habituales de pentesting y ejercicios Red Team. El objetivo no consistía únicamente en verificar vulnerabilidades aisladas, sino demostrar que estas podían encadenarse para comprometer progresivamente distintos sistemas de la infraestructura.

Cada escenario fue ejecutado partiendo de una situación inicial donde el atacante únicamente disponía de conectividad hacia los servicios expuestos por el laboratorio. A partir de este punto se desarrollaron distintas actividades de reconocimiento, explotación y post-explotación hasta alcanzar los objetivos definidos.

Las pruebas se estructuraron en las siguientes fases:

1. Reconocimiento y enumeración de servicios.
2. Identificación de vulnerabilidades.
3. Obtención de acceso inicial.
4. Escalada de privilegios.
5. Pivoting hacia redes internas.
6. Enumeración de Active Directory.

7. Movimiento lateral.
8. Compromiso de sistemas corporativos.

Durante todas las pruebas se registraron evidencias mediante capturas de pantalla, registros de comandos y resultados obtenidos con distintas herramientas ofensivas.

6.2 Escenarios de ataque realizados

Los escenarios de ataque implementados fueron diseñados para validar las distintas superficies de ataque incorporadas al laboratorio y demostrar la viabilidad de una cadena de compromiso completa.

La secuencia seguida reproduce una intrusión progresiva sobre una infraestructura corporativa simulada, donde cada fase proporciona acceso a nuevos recursos y permite avanzar hacia sistemas de mayor criticidad.

6.2.1 Reconocimiento inicial

La primera fase del ejercicio consistió en la identificación de servicios expuestos y la recopilación de información sobre la infraestructura objetivo.

Para ello se emplearon herramientas de enumeración de red como Nmap con el objetivo de identificar hosts accesibles, puertos abiertos y servicios disponibles.

La información obtenida permitió identificar el servidor Ubuntu como principal superficie de ataque expuesta al exterior, así como determinar los servicios web disponibles para su posterior análisis.

El reconocimiento inicial permitió construir una visión general de la infraestructura y definir los vectores de ataque potencialmente explotables.

6.2.2 Explotación web

Una vez identificada la aplicación vulnerable, se procedió al análisis de sus funcionalidades y mecanismos de autenticación.

Durante esta fase se identificaron distintas vulnerabilidades pertenecientes a categorías recogidas por OWASP Top 10. Estas debilidades permitieron obtener acceso a información sensible y ejecutar acciones no autorizadas dentro de la aplicación.

Las pruebas realizadas confirmaron que las vulnerabilidades implementadas pueden ser explotadas de forma controlada y constituyen un punto de entrada válido al entorno.

6.2.3 Obtención de reverse shell

Tras explotar la aplicación web se consiguió ejecutar comandos sobre el servidor vulnerable y establecer una conexión interactiva con la máquina Ubuntu.

La obtención de una reverse shell permitió acceder al sistema operativo subyacente y continuar con actividades de post-explotación fuera del contexto de la aplicación web.

Esta fase demuestra cómo una vulnerabilidad aparentemente limitada puede derivar en el compromiso del sistema que aloja la aplicación.

6.2.4 Escalada de privilegios Linux

Una vez obtenido acceso al servidor Ubuntu se realizaron tareas de enumeración local orientadas a identificar configuraciones inseguras y mecanismos de escalada de privilegios.

Durante el análisis se localizaron diferentes elementos vulnerables introducidos de forma intencionada en el laboratorio, permitiendo incrementar el nivel de privilegios hasta obtener control administrativo completo del sistema.

La correcta explotación de estos mecanismos validó los escenarios de post-explotación previstos durante el diseño del laboratorio.

6.2.5 Pivoting

Con el servidor Ubuntu completamente comprometido se utilizó este sistema como punto intermedio para acceder a segmentos de red inicialmente inaccesibles.

Esta técnica permitió alcanzar recursos internos pertenecientes a la infraestructura corporativa simulada y validar la segmentación de red definida durante el diseño del laboratorio.

El pivoting constituye una de las fases más relevantes del escenario, ya que reproduce situaciones habituales observadas en intrusiones reales.

6.2.6 Enumeración Active Directory

Una vez alcanzada la red interna se llevaron a cabo actividades de reconocimiento orientadas a identificar usuarios, grupos, equipos y servicios pertenecientes al dominio.

Durante esta fase se utilizaron herramientas específicas para entornos Active Directory que permitieron recopilar información sobre la estructura interna de la organización simulada.

Los resultados obtenidos facilitaron la identificación de posibles objetivos para fases posteriores de movimiento lateral y escalada de privilegios.

6.2.7 Movimiento lateral

A partir de las credenciales obtenidas durante las fases anteriores se realizaron intentos de acceso a distintos sistemas internos.

Las pruebas permitieron verificar que un atacante con acceso parcial a la infraestructura puede desplazarse entre diferentes equipos aprovechando relaciones de confianza existentes dentro del dominio.

Esta fase confirmó la correcta integración entre los distintos componentes Windows presentes en el laboratorio.

6.2.8 Compromiso del dominio

La fase final del ejercicio consistió en comprometer los recursos más sensibles de la infraestructura corporativa simulada.

Mediante la combinación de vulnerabilidades, credenciales obtenidas y técnicas de post-explotación fue posible alcanzar un nivel de acceso equivalente al de un administrador del dominio.

Este resultado valida el escenario completo planteado durante el diseño del laboratorio y demuestra cómo una cadena de vulnerabilidades aparentemente independientes puede desembocar en el compromiso total de una organización.

6.3 Validación de reproducibilidad

Uno de los objetivos principales del proyecto consistía en garantizar que el laboratorio pudiera desplegarse de forma consistente en distintos equipos anfitriones.

Para validar este requisito se realizaron varias pruebas de instalación utilizando los procedimientos documentados y los scripts de automatización desarrollados durante el proyecto.

Los resultados obtenidos demostraron que la infraestructura puede desplegarse de forma reproducible manteniendo la misma configuración de red, los mismos servicios y las mismas vulnerabilidades independientemente del entorno utilizado.

Asimismo, las pruebas permitieron verificar que los distintos escenarios de ataque pueden ejecutarse de forma consistente tras cada despliegue, garantizando la utilidad del laboratorio como plataforma docente y de experimentación.

En consecuencia, puede afirmarse que el laboratorio cumple los requisitos de reproducibilidad definidos durante las fases iniciales del proyecto y constituye una base adecuada para futuras ampliaciones y nuevos escenarios de ataque.

Capítulo 7

Conclusiones y trabajo futuro

7.1 Conclusiones

7.2 Líneas futuras

Bibliografía

- [1] OWASP Foundation, *OWASP Top 10:2025*, Consultado en junio de 2026, 2025. dirección: https://owasp.org/Top10/2025/0x00_2025-Introduction/
- [2] MITRE Corporation, *MITRE ATT&CK Framework*, Consultado en junio de 2026, 2025. dirección: <https://attack.mitre.org/>
- [3] OWASP Foundation, *SQL Injection Prevention Cheat Sheet*, Consultado en junio de 2026, 2025. dirección: https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
- [4] OWASP Foundation, *Testing for SQL Injection*, Consultado en junio de 2026, 2025. dirección: https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/07-Input_Validation_Testing/05-Testing_for_SQL_Injection
- [5] OWASP Foundation, *Cross Site Scripting Prevention Cheat Sheet*, Consultado en junio de 2026, 2025. dirección: https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html
- [6] OWASP Foundation, *Types of Cross-Site Scripting*, Consultado en junio de 2026, 2025. dirección: https://owasp.org/www-community/Types_of_Cross-Site_Scripting
- [7] OWASP Foundation, *File Upload Cheat Sheet*, Consultado en junio de 2026, 2025. dirección: https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html
- [8] OWASP Foundation, *Secrets Management Cheat Sheet*, Consultado en junio de 2026, 2025. dirección: https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html
- [9] MITRE Corporation, *Privilege Escalation*, Consultado en junio de 2026, 2025. dirección: <https://attack.mitre.org/tactics/TA0004/>
- [10] GNU Project, *Bash Reference Manual*, Consultado en junio de 2026, 2025. dirección: <https://www.gnu.org/software/bash/manual/bash.html>
- [11] MITRE Corporation, *Proxy: T1090*, Consultado en junio de 2026, 2025. dirección: <https://attack.mitre.org/techniques/T1090/>

- [12] Microsoft, *Active Directory Domain Services Overview*, Consultado en junio de 2026, 2025. dirección: <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/get-started/virtual-dc/active-directory-domain-services-overview>
- [13] Microsoft, *Understanding the Active Directory Logical Model*, Consultado en junio de 2026, 2025. dirección: <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/understanding-the-active-directory-logical-model>
- [14] Microsoft, *Kerberos Authentication Overview in Windows Server*, Consultado en junio de 2026, 2025. dirección: <https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-authentication-overview>
- [15] Microsoft, *Active Directory Security Groups*, Consultado en junio de 2026, 2025. dirección: <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/understand-security-groups>
- [16] Microsoft, *Active Directory Privileged Accounts and Groups Guide*, Consultado en junio de 2026, 2025. dirección: <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/appendix-b--privileged-accounts-and-groups-in-active-directory>
- [17] Microsoft, *What is SMB File Sharing for Windows and Windows Server?* Consultado en junio de 2026, 2025. dirección: <https://learn.microsoft.com/en-us/windows-server/storage/file-server/file-server-smb-overview>
- [18] Microsoft, *Windows Remote Management*, Consultado en junio de 2026, 2025. dirección: <https://learn.microsoft.com/en-us/windows/win32/winrm/portal>
- [19] MITRE Corporation, *Lateral Movement, Tactic TA0008 - Enterprise*, Consultado en junio de 2026, 2025. dirección: <https://attack.mitre.org/tactics/TA0008/>

Anexo i - Manual de despliegue

Anexo ii - Manual de explotación

Anexo iii - Configuración de red

Anexo iv - Scripts y automatizaciones

Anexo v - Evidencias adicionales

Glosario de siglas

AD Active Directory.

Apache Apache HTTP Server.

API Interfaz de Programación de Aplicaciones.

CPU Central Processing Unit.

CVE Common Vulnerabilities and Exposures.

CWE Common Weakness Enumeration.

DNS Domain Name System.

DVWA Damn Vulnerable Web Application.

Git Sistema de control de versiones distribuido.

GitHub Plataforma de alojamiento y gestión de repositorios Git.

HTTP HyperText Transfer Protocol.

HTTPS HyperText Transfer Protocol Secure.

IP Internet Protocol.

LAN Local Area Network.

MITRE ATT&CK Adversarial Tactics, Techniques and Common Knowledge.

MySQL My Structured Query Language.

NAT Network Address Translation.

OWASP Open Worldwide Application Security Project.

PHP PHP Hypertext Preprocessor.

RAM Random Access Memory.

SMB Server Message Block.

SQL Structured Query Language.

SQLi SQL Injection.

SSH Secure Shell.

VM Máquina Virtual.

WinRM Windows Remote Management.

XFCE XForms Common Environment.

XSS Cross-Site Scripting.

Definiciones

Movimiento lateral Conjunto de técnicas utilizadas por un atacante para desplazarse entre distintos sistemas de una red tras obtener acceso inicial.

Pentesting Proceso autorizado de evaluación de la seguridad de un sistema mediante técnicas de ataque controladas.

Pivoting Técnica que permite utilizar un sistema comprometido como punto de acceso para alcanzar otros sistemas de una red interna.

Red Host-Only Tipo de red virtual aislada que permite la comunicación entre máquinas virtuales y el equipo anfitrión sin exponerlas a redes externas.

Red Team Disciplina de seguridad ofensiva orientada a simular ataques reales para evaluar la capacidad de detección y respuesta de una organización.

Snapshot Captura instantánea del estado completo de una máquina virtual que permite restaurarla posteriormente.